State of New Hampshire
Department of Information Technology
Office of the Chief Information Security Officer (CISO)
Supply Chain Risk Management Policy

1. PURPOSE

The purpose of the Supply Chain Risk Management policies and standards is to ensure that supply chain risks are appropriately identified, assessed, and managed to limit harm or consequences from supply chain-related events.

This policy is part of the library of Statewide processes that supports the State of New Hampshire's information security program that is collectively referred to as the Statewide Information Security Manual, or "SISM". The SISM is applicable to all Departments, Agencies, Commissions, Boards, Bodies, or other instrumentalities of the Executive Branch of New Hampshire State Government.

NIST SP 800-53 Rev. 5 Controls: SR-1

2. APPLICABILITY

All Executive Branch authorized users including full-time and part-time employees, temporary workers, volunteers, interns, affiliates (contractors) are governed by and responsible for complying with the SISM regardless of agency, location, or role.

2.1. SECURITY CONTROLS

This policy has been mapped to the applicable standard and the standard tags are contained in the procedure's metadata and listed here.

NIST SP 800-53 Rev. 5 Controls:

- SR Supply Chain Risk Management

3. ROLES AND RESPONSIBILITIES

- Agencies
- Retrieving Agency
- SISM Users

Agencies shall employ processes and procedures to protect against supply chain risks to systems, system components, or system services and to limit the harm or consequences from supply chain-related events.

Information systems (including system components that compose those systems) need to be protected throughout the system development life cycle (i.e., during design, development, manufacturing, packaging, assembly, distribution, system integration, operations, maintenance, and retirement).

NIST SP 800-53 Rev. 5 Controls: SR-01

SUPPLY CHAIN RISK MANAGEMENT PLAN

The dependence on products, systems, and services from external providers, as well as the nature of the relationships with those providers, present an increasing level of risk to the State. Threat actions that may increase security or privacy risks include unauthorized production, the insertion or use of counterfeits, tampering, theft, insertion of malicious software and hardware, and poor manufacturing and development practices in the supply chain. Supply chain risks can be endemic or systemic within a system element or component, a system, an Organization, a sector, or the Nation.

Where feasible, SISM Users shall:

- Develop a plan for managing supply chain risks associated with the research and development, design, manufacturing, acquisition, delivery, integration, operations and maintenance, and disposal of Agency systems, system components or system services.
- Review and update the supply chain risk management plan as required, to address threat, organizational, or environmental changes.
- Protect the supply chain risk management plan from unauthorized disclosure and modification.
- Establish a supply chain risk management team consisting of information technology, security, privacy, legal, and procurement Personnel who lead and support acquisition and procurement activities.

Managing supply chain risk is a complex, multifaceted undertaking that requires a coordinated effort across all Agencies to build trust relationships and communicate with internal and external stakeholders. Supply chain risk management (SCRM) activities include identifying and assessing risks, determining appropriate risk response actions, developing SCRM plans to document response actions, and monitoring performance against plans. The SCRM plan (at the system-level) is implementation specific, providing policy implementation, requirements, constraints, and implications. In the absence of a sustainable and executable specific SCRM plan, the State shall use the Risk Assessment Procedures to inform risk-based decisions on supply chain risk.

NIST SP 800-53 Rev. 5 Controls: SR-02

SUPPLY CHAIN CONTROLS AND PROCESSES

Where feasible, SISM Users shall:

- Establish processes and procedures to identify and address weaknesses or deficiencies in the supply chain elements including:
    - Hardware, software, and firmware development processes.

- Shipping and handling procedures.
- Personnel security and physical security programs.

Supply chain elements include Agencies, entities, or tools employed for the research and development, design, manufacturing, acquisition, delivery, integration, operations and maintenance, and disposal of systems and system components. Supply chain elements and processes may be provided by Organizations, system integrators, or external providers. Weaknesses or deficiencies in supply chain elements or processes represent potential vulnerabilities that can be exploited by adversaries to cause harm to the Organization and affect its ability to carry out its core missions or business functions. In the absence of a sustainable and executable specific SCRM plan, the State shall use the Risk Assessment Procedures to inform risk-based decisions on supply chain risk.

NIST SP 800-53 Rev. 5 Controls: SR-03

ACQUISITION STRATEGIES, TOOLS, AND METHODS

Agencies shall employ the following acquisition strategies, contract tools, and procurement methods to protect against, identify, and mitigate supply chain risks:

- Adhering to all State and Federal laws, executive orders, circulars, policies, and guidelines pertaining to procurements of systems, system components, and/or services.
- Where feasible, obscuring the end use of a system or system component.
- Requiring tamper-evident packaging.
- Using trusted or controlled distribution.

Agencies should contact the Department of Information Technology and/or the Department of Administrative Services Division of Purchase and Property for guidance regarding applicable State and Federal laws, executive orders, circulars, directives, regulations, policies, and guidelines policies governing the procurement of systems, system components, and services.

Tools and techniques may provide protections against unauthorized production, theft, tampering, insertion of counterfeits, insertion of malicious software or backdoors, and poor development practices throughout the system development life cycle.

NIST SP 800-53 Rev. 5 Controls: SR-05

SUPPLIER ASSESSMENTS AND REVIEWS

Where feasible, Agencies shall assess and review the supply chain-related risks associated with suppliers or contractors and the system, system component, or system service they provide:

- Prior to contracting with a supplier.
- At least annually thereafter.
- In response to a supply chain incident involving the supplier.

- Upon changes to the supplier's organizational structure or environment.

An assessment and review of supplier risk includes security and supply chain risk management processes, foreign ownership, control, or influence (FOCI), and the ability of the supplier to effectively assess subordinate second-tier and third-tier suppliers and contractors.

Agencies can use open-source information to monitor for indications of stolen information, poor development and quality control practices, information spillage, or counterfeits.

Agencies should review the US Department of Commerce Bureau of Industry and Security Lists of Parties of Concern, the International Trade Association Consolidated Screening List, and the National Defense Authorization Act (NDAA) Section 889 prior to contracting with a supplier. In general, Agencies should avoid purchasing systems, system components, and services from companies on these lists due to threats they pose to the State and/or Nation. Agencies should contact the NHCIC for further guidance.

NIST SP 800-53 Rev. 5 Controls: SR-06

NOTIFICATION AGREEMENTS

Agencies shall establish agreements and procedures with entities involved in the system, system component, or system service supply chain requiring notification of supply chain compromises; results of assessments or audits; and remediation plans, as applicable.

The establishment of agreements and procedures facilitates communications among supply chain entities. Early notification of compromises and potential compromises in the supply chain that can potentially adversely affect or have adversely affected Agency systems or system components is essential for Organizations to effectively respond to such incidents. The results of assessments or audits may include open-source information that contributed to a decision or result and could be used to help the supply chain entity resolve a concern or improve its processes.

NIST SP 800-53 Rev. 5 Controls: SR-08

INSPECTION OF SYSTEMS OR COMPONENTS

Upon receipt of systems and/or systems components, the receiving Agency must inspect the packaging, bill of lading, packing slip, systems and/or system components for any signs of tampering with the system or systems components.

Agencies should develop processes to inspect systems and systems components any time the system or component is removed from Agency-controlled areas (e.g., system and components sent out for repair and returned to the Agency) and/or when Individuals return from travel to high-risk areas. Indications of a need for inspection include changes in packaging, specifications, factory location, or entity in which the part is purchased.

NIST SP 800-53 Rev. 5 Controls: SR-10

COMPONENT AUTHENTICITY

SISM Users shall:

- Not knowingly procuring counterfeit systems or systems components.
- Employ a risk-based approach to reduce the frequency and impact of counterfeit systems or system components within Agency acquisitions and Agency life-cycle sustainment processes by:
    - Applying prevention and early detection procedures to minimize the presence of counterfeit components within the Agency supply chain as the primary strategy in eliminating counterfeit materiel within the Agency.
    - Strengthening the oversight and surveillance procedures for critical and sensitive systems and system components; and
    - Maintaining configuration control over system components awaiting service or repair and serviced or repaired components awaiting return to service.
- Document all occurrences of suspect and confirmed counterfeit systems and system components.
- Through the Attorney General's Office, investigate, analyze, and assess all cases of suspected counterfeit systems and systems components.
- Notify Agency Management, the NHCIC, DoIT, the Division of Administrative Services, and the source of the counterfeit component.
- Seek restitution when cases are confirmed.
- Provide awareness training to Agency Staff to include responsibilities and processes for inspection and reporting of suspected counterfeit systems and system components.

Sources of counterfeit components include manufacturers, developers, vendors, and contractors. Anti-counterfeiting policies and procedures support tamper resistance and provide a level of protection against the introduction of malicious code.

NIST SP 800-53 Rev. 5 Controls: SR-11

COMPONENT DISPOSAL

In accordance with all applicable State and Federal laws, executive orders, circulars, directives, and policies regarding the disposal of systems and system components, Agencies shall first sanitize all media containing sensitive information, software, documentation, etc., from systems and system components prior to disposal.

Data, documentation, tools, or system components can be disposed of at any time during the system development life cycle (not only in the disposal or retirement phase of the life cycle). Opportunities for compromise during disposal affect physical and logical data, including system documentation in paper-based or digital files; shipping and delivery documentation; memory sticks with software code; or complete routers, servers, and multi-function devices that include permanent media, and may contain sensitive or proprietary information. NH White Farm Surplus Procedures require positive attestation that Media Sanitization has occurred or is not necessary.

NIST SP 800-53 Rev. 5 Controls: SR-12

4. REFERENCES

- NIST CSF Identify – Business Environment (ID.BE), Protect – Awareness and Training (PR.AT), Identify – Governance (ID.GV), Identify – Supply Chain (ID.SC)
- NIST SP 800-53 Rev. 5 Standard which can be found at: https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final.
- NHS0242 Systems and Services Acquisition Policy (SA)

REVISION HISTORY:
The New Hampshire State Chief Information Security Officer (CISO) shall update the Revision History table below to document all new or substantive changes in alignment with NHS0168 DoIT's Control of Documented Information Policy.

The effective date of any added, changed, updated, or deleted policy shall be the date of entry in the Revision History table.

Version	Date	Description	CISO Signature
1.0	8/5/22	Initial issue of Statewide Information Security Manual (SISM) using NIST 800-53 Rev. 5 Moderate Baseline.	KLW-8/5/2022
2.0	9/7/23	Reviewed, no change to content; update to new template as stand-alone policy.	KLW-9/7/23
3	8/7/24	Micro changes including: • Add blanket language to Purpose to indicate that this policy is part of the library of Statewide processes that supports the State of New Hampshire's information security program. • Revise applicability statement for clarity. • Added leading zero to security controls to align with NIST 800-53 R5. • Update references to align with current process.	D. Schelb 8/7/24